

Индивидуальный проект. Этап 4

Использование nikto

Жукова А. А.

26 апреля 2025

Российский университет дружбы народов, Москва, Россия

Информация

- Жукова Арина Александровна
- Студент бакалавриата, 2 курс
- группа: НПИбд-03-23
- Российский университет дружбы народов
- 1132239120@rudn.ru

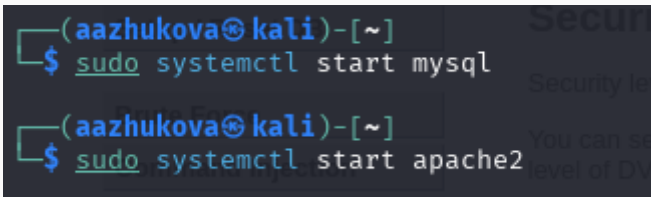


Вводная часть

Научиться выявлять возможные уязвимости в веб-серверах при помощи приложения nikto.

Ход выполнения работы

Запускаем сервер при помощи команд `systemctl start` "то, что запускаем".

A terminal window with a dark background. The prompt is `(aazhukova@kali)-[~]`. The first command entered is `$ sudo systemctl start mysql`. The second command entered is `$ sudo systemctl start apache2`.

```
(aazhukova@kali)-[~]  
$ sudo systemctl start mysql  
  
(aazhukova@kali)-[~]  
$ sudo systemctl start apache2
```

Рис. 1: Запуск сервера

2. Через терминал запускаем приложение для сканирования nikto

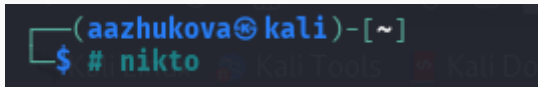


Рис. 2: Запуск приложения

3. Запускаем сканирование, указывая ссылку http

```
(aazhukova@kali)-[~]
$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.5.0

+ Target IP:      127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port:    80
+ Start Time:     2025-04-26 19:22:12 (GMT3)

+ Server: Apache/2.4.63 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS
+ /DVWA///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aa%20aa%27cat%20/etc/hosts: Some D-Link router remote command execution.
+ /DVWA/shell?cat=/etc/hosts: A backdoor was identified.
```

4. Запускаем сканирование, указывая ip-адрес и порт

```
(aazhukova@kali)-[~]  
$ nikto -h 127.0.0.1 -p 80  
- Nikto v2.5.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Start Time: 2025-04-26 19:25:01 (GMT3)  
  
+ Server: Apache/2.4.63 (Debian)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ No CGI Directories found (use '-C all' to force check all possible dirs)  
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 63298273a1a18, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .  
+ /etc/passwd: The server install allows reading of any system file by adding an extra '/' to the URL.  
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=/etc/passwd: A PHP backdoor file manager was found.  
+ /login.cgi?cli=aa%20aa%27cat%20/etc/passwd: Some D-Link router remote command execution.  
+ /shell?cat=/etc/passwd: A backdoor was identified.  
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host  
+ End Time: 2025-04-26 19:25:17 (GMT3) (16 seconds)  
  
+ 1 host(s) tested
```

Можем указывать различные параметры, в зависимости от требований:

1. -h Указывает целевой веб-сервер для сканирования. Например, -h example.com
2. -p Указывает порт, на котором работает веб-сервер.
3. -ssl Активирует сканирование через SSL/TLS.
4. -id Указывает пользовательский User-Agent для передачи веб-серверу.
5. -o Указывает файл для сохранения результатов сканирования.
6. -Plugins Активирует определенные плагины для сканирования. Например, -Plugins auto,nikto
7. -Tuning Указывает профиль настроек для сканирования. Например, -Tuning 3

Вывод

В ходе выполнения данного этапа были приобретены практические навыки использования базового сканера безопасности веб-серверов nikto.

Список литературы. Библиография

1] Парасрам, Ш. Kali Linux: Тестирование на проникновение и безопасность : Для профессионалов. Kali Linux / Ш. Парасрам, А. Замм, Т. Хериянто, и др. – Санкт-Петербург : Питер, 2022. – 448 сс.